

Processing Personal Data under the EU AI Act: Interaction and Conflict with the GDPR

Marlon Müller¹

¹Technical University of Munich, Germany

Introduction

The training of Artificial Intelligence (AI) systems relies heavily on the processing of large amounts of data. In practice a large share of this data is personal data. This overlap between AI and personal data processing brings two major regulatory instruments of the European Union (EU) into contact: the General Data Protection Regulation (GDPR) and the Artificial Intelligence Act (AIA).

Both regulatory frameworks have the same goal of protecting fundamental rights and freedoms of individuals, and they both apply simultaneously to providers of high-risk AI systems that process personal data. This relationship is conceptualized as an additive one in Art. 2(7) AIA [1]. They also follow a different regulatory logic, with the GDPR protecting the fundamental right of privacy and the AIA acting as a product safety regulation for AI systems.

This paper analyzes how this co-regulation affects providers and argues that the relationship is more complex than the AIA's additive model suggests. For this purpose, the paper first establishes a role mapping and will then examine the parallel obligations that arise from the two frameworks. Finally, it will show that the debiasing exception in Art. 10(5) AIA creates a conflict, that neither framework can resolve on its own.

Two Frameworks, One Actor

In both regulations there are distinct roles that entities can take on and that have different legal obligations. The GDPR distinguishes between data controllers and data processors, while the AIA distinguishes between providers and deployers of AI systems. In practice the roles of the two frameworks do not map onto each other statically, even though they often overlap if personal data that falls under the GDPR is involved.

During the development and training of an AI system the provider can usually be considered to be the data controller, as it determines the purposes and means of the processing of personal data. Even

though the provider can still give instructions to the deployer during the deployment phase on how to use the system and how to handle personal data, these constraints are merely technical and are not sufficient to make the provider a data processor during deployment. This role will be taken on by the deployer instead, as he keeps control over the purposes of the processing of personal data and, most crucially, can control who is a data subject, usually customers of the deployer, of that processing. If the inference does not run on the deployer's infrastructure and personal data flows to the server the AI system is hosted on, the natural or legal person that operates that server, which is either the provider, importer or distributor of the AI system, can be considered a data processor during inference. If the system is self-hosted by the deployer, the provider exits the processing chain entirely and is not subject to GDPR after deployment. [1, 2]

While the mapping of these roles is grounded in the legal definitions of the two frameworks and the practical realities of AI development and deployment, there may nevertheless be edge cases or legal and contractual constellations in which this mapping does not hold.

One important gap of the overlap of these roles can be found whenever the provider of a continuous learning system feeds inference data back into retraining. In this case, the provider may transition from processor to controller for that secondary processing, as it determines a new purpose for its own benefit. This practice could conflict with GDPR Articles 5(1)(b) and 6 [2], but the AIA addresses it only obliquely through Article 15 on feedback loops, without addressing or resolving the GDPR consequences [1].

Parallel Obligations

Data Governance

Right to be Forgotten

Transparency Obligations

The Debiasing Exception

Conclusion

References

- [1] European Parliament and Council of the European Union. "Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act)". In: *Official Journal of the European Union* L 305 (2024). CELEX number: 32024R1689, pp. 1–73. URL: <http://europa.eu>.
- [2] European Parliament and Council of the European Union. "Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation)". In: *Official Journal of the European Union* L 129.L 129 (2016).